

		개발부서	
		보안 담당자	이 규 호 (인)
		담당자	(인)
		부서장	(인)

점검 영역 및 항목		주요 검토 내용	점검 결과	조치 요구사항 및 비고
인/기업정보 처리여부				
정보 취급 여부 확인	개발 대상 시스템/서비스가 개인정보 및 기업의 중요 정보(기밀 등)를 수집, 이용, 제공하는가?	☐ 양호 ☐ 취약		
수집/저장 계획 확인	수집된 데이터의 저장소(DB, 파일 서버 등)에 보관 할 계획이 있는가?	☐ 양호 ☐ 취약		
보관 및 파기 정책 수립 여부	보관 목적 및 보유 기간(유효기간)*에 대한 정책 적용 하고 있는가? (보유 기간 만료 시 또는 서비스 탈퇴 시 데이터를 파기 여부)	☐ 양호 ☐ 취약		
DB UL/DL 기능 개발 여부	데이터베이스(DB)에 대량의 데이터를 업로드(UL)하거나 다운로드(DL, 엑셀 출력 등)하는 기능이 존재하는가?	☐ 양호 ☐ 취약		
용자 인증 및 세션 관리				
사용자 인증	로그인 계정 생성 및 2차 인증 적용 계획이 있는가?	☐ 양호 ☐ 취약		
비밀번호 복잡성 정책	영문/숫자/특수문자 조합, 최소 8~10자리 이상 설정 및 유효성 검증을 서버 측에서 수행하는가?	☐ 양호 ☐ 취약		
로그인 시도 제한	연속 실패 시(예: 5회 이상) 계정 잠금 발동하는가?	☐ 양호 ☐ 취약		
세션 타임아웃	일정 시간(예: 30분) 동안 활동이 없으면 세션을 만료하고 자동 로그아웃시키는가?	☐ 양호 ☐ 취약		
계정 정책	장기 미사용, 퇴사자 등 계정 정책에 대한 관리 계획이 있는가?	☐ 양호 ☐ 취약		
한 부여 및 접근 제어				
URL 직통 접근 차단	로그인 후 메뉴에는 안 보이지만 관리자 페이지 URL(예: /admin/user_list)을 직접 입력했을 때 접근이 차단되는가?	☐ 양호 ☐ 취약		
역할 기반 접근제어(RBAC) 적용	사용자, 관리자, 운영자 등 역할별 권한 체계 적용 여부 확인	☐ 양호 ☐ 취약		
기본 관리자 계정 변경	웹 애플리케이션 프레임워크나 WAS, DB의 초기 기본 관리자 계정(admin/admin 등)을 변경했는가?	☐ 양호 ☐ 취약		
력값 검증 및 데이터 보호				
소스코드 Private 설정 여부	소스코드가 외부에 노출되지 않도록 설정을 적용하고 있는가?	☐ 양호 ☐ 취약		
소스코드 접근통제 및 변경 관리	개발 코드 및 프로젝트 권한자로 제한하고 있으며, 변경사항에 대해 추적 관리를 수행하고 있는가?(Git/SVN/Jenkins 등 활용관리)	☐ 양호 ☐ 취약		
안전한 파일 업로드	첨부파일 업로드 시 실행 파일(.jsp, .php, .asp, .exe 등)을 금지하는 화이트리스트 필터링이 적용되었는가?	☐ 양호 ☐ 취약		
중요 정보 암호화 저장	계약서, 고객정보, 설계도면 등 중요 파일 암호화 저장 여부	☐ 양호 ☐ 취약		
스크립트 실행 차단 여부	사용자 게시판이나 입력 폼에 텍스트 입력 시 HTML 태그 및 스크립트 실행이 차단(XSS 방어)되도록 필터링하는가?	☐ 양호 ☐ 취약		
오픈소스 취약점 보완 여부	개발에 사용된 외부 라이브러리/프레임워크의 알려진 취약점 여부를 주기적으로 점검하고 최신 패치를 적용하는가?	☐ 양호 ☐ 취약		
송 보안 및 웹 서버 설정				
전구간 SSL/TLS 적용	웹 서비스 전체 페이지에 HTTPS가 적용되어 있으며, 구버전 프로토콜(TLS 1.0, 1.1)은 비활성화(TLS 1.2 이상 권장)했는가?	☐ 양호 ☐ 취약		
에러 페이지 통제	404(클라이언트 PC URL 접속불가), 500(서버에러) 에러 발생 시 톱캣/엔진엑스(Nginx) 버전 정보나 소스코드 라인, DB 에러 메시지가 그대로 화면에 노출되지 않도록 커스텀 에러 페이지를 설정했는가?	☐ 양호 ☐ 취약		
불필요한 HTTP 메소드 차단	GET, POST 외에 불필요한 메소드(OPTIONS, PUT, DELETE, TRACE)를 웹 서버 설정에서 차단했는가?	☐ 양호 ☐ 취약		
디렉토리 리스팅 제거	URL 경로 뒤에 파일명을 입력하지 않고 폴더 경로만 입력했을 때, 폴더 내 파일 목록이 웹 브라우저에 그대로 노출되지 않도록 설정했는가?	☐ 양호 ☐ 취약		
그 및 모니터링				
감사 로그 기록	로그인 성공/실패, 권한 변경, 중요 데이터(개인정보 등) 조회/수정/삭제 시 일시, 수행자 IP, 수행 작업이 로그로 남는가?	☐ 양호 ☐ 취약		
로그 내 민감정보 제외	개발 편의를 위해 소스코드나 로그 파일에 사용자의 비밀번호나 개인정보를 그대로 기록하도록 구현되어 있지 않은가?	☐ 양호 ☐ 취약		
로그 정보 마스킹 적용 여부	로그 정보에 개인정보나 기밀정보 등 민감정보나 기밀정보를 포함하는 정보가 노출되는지 확인하고 마스킹 적용 여부	☐ 양호 ...		